SSRF

SSRF là viết tắt của Server-Side Request Forgery (Tấn công giả mạo yêu cầu phía máy chủ). Đây là một lỗ hổng cho phép người dùng độc hại khiến máy chủ web thực hiện thêm hoặc sửa đổi yêu cầu HTTP tới tài nguyên do kẻ tấn công lựa chọn.

Có hai loại lỗ hổng SSRF; loại thứ nhất là SSRF thông thường, trong đó dữ liệu được trả về màn hình của kẻ tấn công. Loại thứ hai là lỗ hổng SSRF mù, trong đó SSRF xảy ra, nhưng không có thông tin nào được trả về màn hình của kẻ tấn công.

1. Finding an SSRF

Các lỗ hổng SSRF tiềm ẩn có thể được phát hiện trong các ứng dụng web bằng nhiều cách khác nhau. Dưới đây là ví dụ về bốn vị trí phổ biến cần kiểm tra:

Khi sử dụng URL đầy đủ làm tham số trong thanh địa chỉ:

https://website.thm/form?server=http://server.website.thm/store

Một trường ẩn trong biểu mẫu:

```
<form method="post" action="/form">
    <input type="hidden" name="server" value="http://server.website.thm/store">
    <div>Your Name:</div>
    <div><input name="client_name"></div>
    <div>Your Email:</div>
    <div><input name="client_email"></div>
    <div>Your Message:</div>
    <div><textarea name="client_message"></textarea></div>
</form>
```

Một URL không đầy đủ, ví dụ như chỉ có tên máy chủ:

https://website.thm/form?server=api

Hoặc có thể chỉ là đường dẫn của URL:

https://website.thm/form?dst=/forms/contact

Based on simple observation, which of the following URLs is more likely to be vulnerable to SSRF?

1. https://website.thm/index.php
2. https://website.thm/list-products.php?categoryId=5325
3. https://website.thm/fetch-file.php?fname=242533.pdf&srv=filestorage.cloud.thm&port=8001
4. https://website.thm/buy-item.php?itemId=213&price=100&q=2

3 ✓ Correct Answer

https://website.thm/fetch-file.php?fname=242533.pdf&srv=filestorage.cloud.thm&port=8001 → Đây là URL **rõ ràng nhất** có nguy cơ SSRF vì:

- fetch-file.php → tên trang đã nói là "lấy file".
- srv= → viết tắt của **server** (máy chủ).
- port= → chỉ rõ **cổng** (port).
- fname= → tên file.

2. Defeating Common SSRF Defenses

Các nhà phát triển am hiểu về bảo mật, nhận thức được rủi ro của các lỗ hổng SSRF, có thể triển khai các kiểm tra trong ứng dụng của họ để đảm bảo tài nguyên được yêu cầu đáp ứng các quy tắc cụ thể. Thường có hai cách tiếp cận cho việc này, hoặc là danh sách từ chối (deny list) hoặc là danh sách cho phép (allow list).

Deny list

Danh sách từ chối (Deny List) là nơi tất cả các yêu cầu được chấp nhận ngoại trừ các tài nguyên được chỉ định trong danh sách hoặc khớp với một mẫu cụ thể. Một ứng dụng web có thể sử dụng danh sách từ chối để bảo vệ các điểm cuối nhạy cảm, địa chỉ IP hoặc tên miền khỏi bị truy cập bởi công chúng trong khi vẫn cho phép truy cập vào các vị trí khác. Một điểm cuối cụ thể để hạn chế truy cập là localhost, nơi có thể chứa dữ liệu hiệu suất máy chủ hoặc thông tin nhạy cảm khác, vì vậy các tên miền như localhost và 127.0.0.1 sẽ xuất hiện trong danh sách từ chối. Kẻ tấn công có thể vượt qua danh sách từ chối bằng cách sử dụng các tham chiếu localhost thay thế như 0, 0.0.0.0, 0000, 127.1, 127.*.*.*, 2130706433, 017700000001 hoặc các tên miền phụ có bản ghi DNS phân giải thành địa chỉ IP 127.0.0.1, chẳng hạn như 127.0.0.1.nip.io.

Ngoài ra, trong môi trường điện toán đám mây, việc chặn truy cập vào địa chỉ IP 169.254.169.254, chứa siêu dữ liệu cho máy chủ đám mây đã triển khai, bao gồm cả thông tin có thể nhạy cảm, là điều rất có lợi. Kẻ tấn công có thể vượt qua điều này bằng cách đăng ký một tên miền phụ trên tên miền của chúng với bản ghi DNS trỏ đến địa chỉ IP 169.254.169.254.

Allow list

Danh sách cho phép là nơi tất cả các yêu cầu bị từ chối trừ khi chúng xuất hiện trong danh sách hoặc khớp với một mẫu cụ thể, chẳng hạn như quy tắc URL được sử dụng trong tham số phải bắt đầu bằng https://website.thm. Kẻ tấn công có thể nhanh chóng vượt qua quy tắc này bằng cách tạo một tên miền phụ trên tên miền của kẻ tấn công, chẳng hạn như https://website.thm.attackers-domain.thm. Logic ứng dụng lúc này sẽ cho phép đầu vào này và cho phép kẻ tấn công kiểm soát yêu cầu HTTP nội bộ.

Open Redirect

Nếu các biện pháp vượt qua trên không hiệu quả, kẻ tấn công vẫn còn một thủ đoạn nữa, đó là chuyển hướng mở. Chuyển hướng mở là một điểm cuối trên máy chủ mà tại đó khách truy cập trang web được tự động chuyển hướng đến một địa chỉ trang web khác. Ví dụ, hãy xem liên kết https://website.thm/link?url=https://tryhackme.com. Điểm cuối này được tạo ra để ghi lại số lần khách truy cập nhấp vào liên kết này cho mục đích quảng cáo/tiếp thị. Nhưng hãy tưởng tượng có một lỗ hổng SSRF tiềm ẩn với các quy tắc nghiêm ngặt chỉ cho phép các URL bắt đầu bằng

https://website.thm/. Kẻ tấn công có thể sử dụng tính năng trên để chuyển hướng yêu cầu HTTP nội bộ đến một tên miền do kẻ tấn công lựa chọn.

3. Practical

Chúng ta sẽ thực hành trên trang web do tryhackme cung cấp và trả lời câu hỏi.

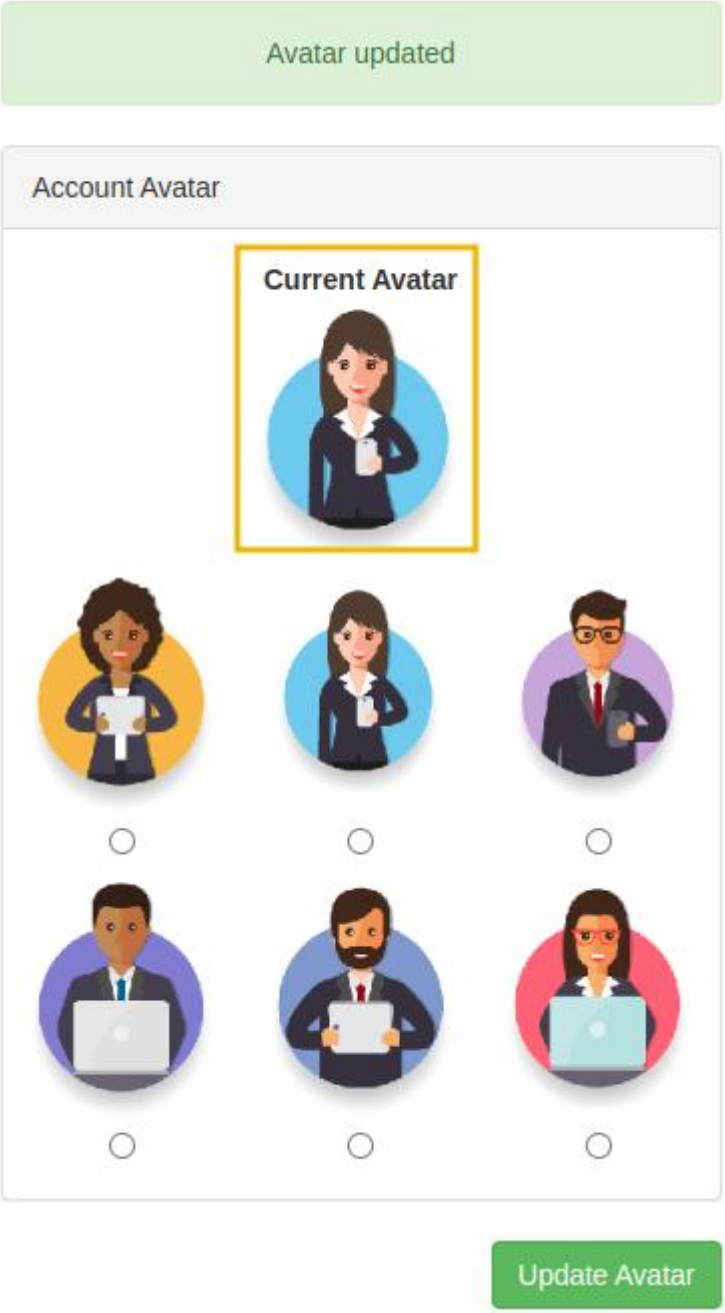
Nội dung tryhackme viết:

Chúng tôi đã phát hiện ra hai điểm cuối mới trong quá trình khám phá nội dung trên trang web Hỗ trợ CNTT Acme. Điểm cuối đầu tiên là /private, cho chúng tôi một thông báo lỗi giải thích rằng nội dung không thể được xem từ địa chỉ IP của chúng tôi. Điểm cuối thứ hai là một phiên bản mới của trang tài khoản khách hàng tại /customers/new-account-page với một tính năng mới cho phép khách hàng chọn ảnh đại diện cho tài khoản của họ.

Đầu tiên, hãy tạo một tài khoản khách hàng và đăng nhập. Sau khi đăng nhập, hãy truy cập https://10-48-155-6.reverse-proxy.cell-prod-ap-south-1a.vm.tryhackme.com/customers/new-account-page để xem tính năng chọn ảnh đại diện mới. Bằng cách xem mã nguồn trang của biểu mẫu ảnh đại diện, bạn sẽ thấy giá trị của trường biểu mẫu ảnh đại diện chứa đường dẫn đến hình ảnh. Kiểu thuộc tính background-image có thể xác nhận điều này trong phần tử DIV ở trên như trong ảnh chụp màn hình bên dưới:

```
<div class="col-xs-4">
    <div class="avatar-image" style="background-image: url('/assets/avatars/1.png')"></div>
    <input type="radio" name="avatar" value="assets/avatars/1.png">
</div>
```

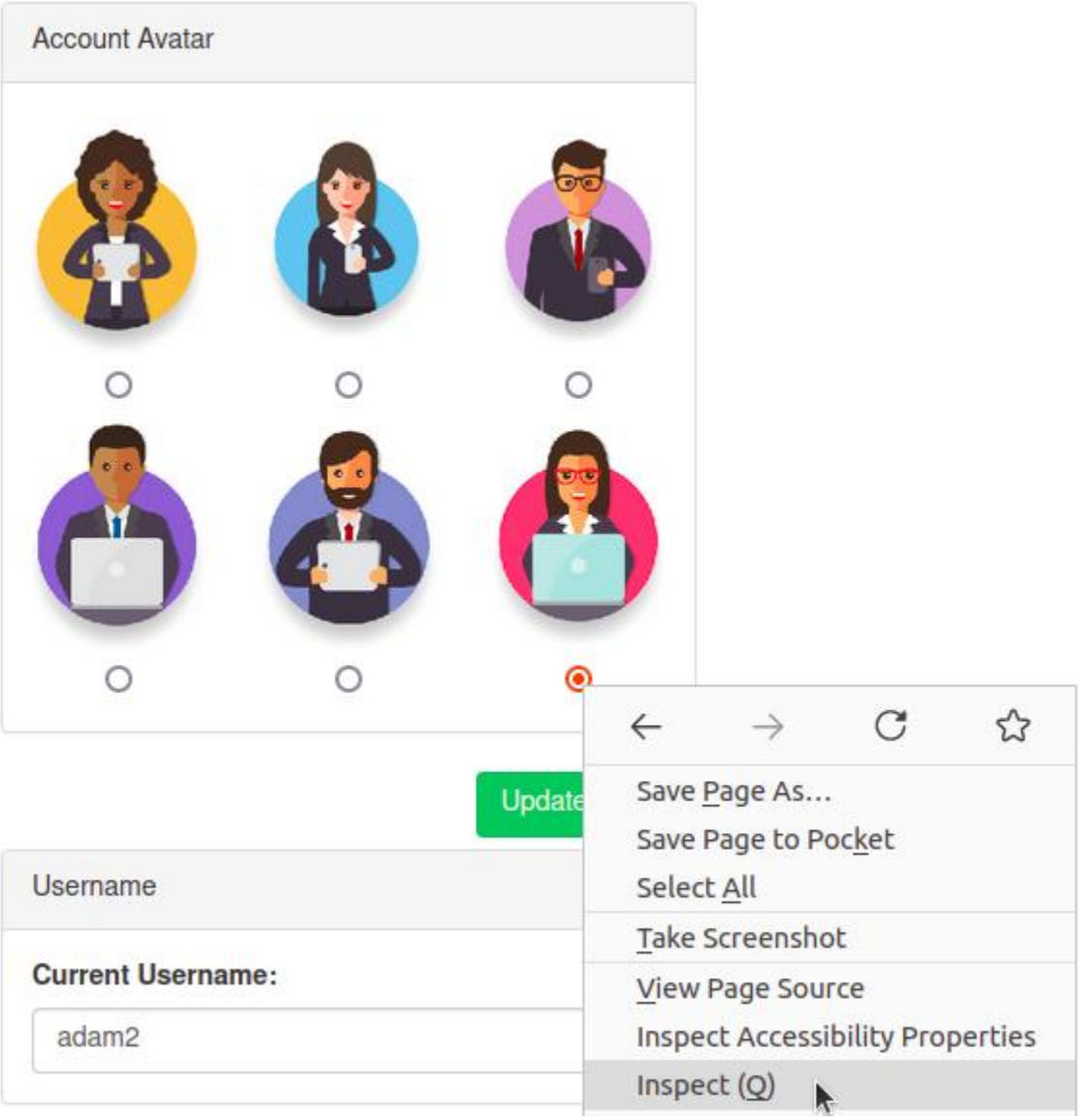
Nếu bạn chọn một trong các hình đại diện rồi nhấp vào nút Cập nhật hình đại diện, bạn sẽ thấy biểu mẫu thay đổi và hình đại diện bạn vừa chọn sẽ hiển thị ở phía trên.



Khi xem mã nguồn trang, bạn sẽ thấy hình đại diện hiện tại của bạn được hiển thị bằng lược đồ URI dữ liệu, và nội dung hình ảnh được mã hóa base64 như trong ảnh chụp màn hình bên dưới.

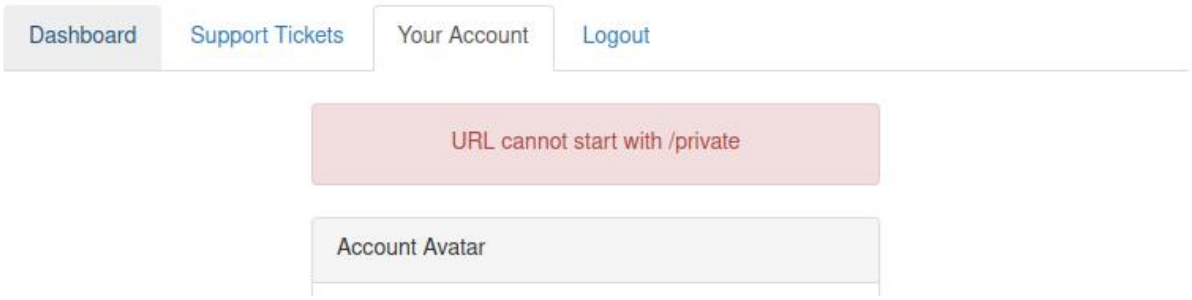
```
<div class="col-xs-6 col-xs-offset-3">
    <div><strong>Current Avatar</strong></div>
    <div class="avatar-image" style="background-image: url(
</div>
```

Bây giờ chúng ta hãy thử gửi yêu cầu lại nhưng thay đổi giá trị avatar thành private với hy vọng máy chủ sẽ truy cập được tài nguyên và vượt qua được việc chặn địa chỉ IP. Để làm điều này, trước tiên, hãy nhấp chuột phải vào một trong các nút radio trên biểu mẫu avatar và chọn Inspect:




```
<div class="col-xs-4">
  <div class="avatar-image" style="background-image: url('/assets/avatars/6.png')"></div>
  <input type="radio" name="avatar" value="private">
</div>
```

Hãy chắc chắn chọn ảnh đại diện bạn vừa chỉnh sửa rồi nhấp vào nút Cập nhật ảnh đại diện. Rất tiếc, có vẻ như ứng dụng web đã thiết lập danh sách từ chối và đã chặn quyền truy cập vào điểm cuối /private.



Như bạn thấy từ thông báo lỗi, đường dẫn không được bắt đầu bằng /private nhưng đừng lo, chúng ta vẫn còn cách để vượt qua quy tắc này. Chúng ta có thể sử dụng thủ thuật duyệt thư mục để đến được điểm cuối mong muốn. Hãy thử đặt giá trị avatar thành x/../private

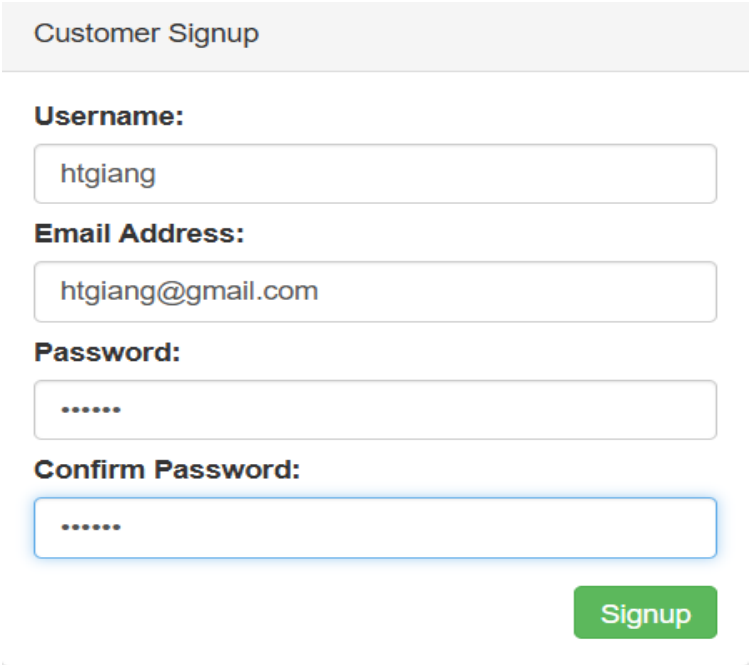
```
<div class="col-xs-4">
  <div class="avatar-image" style="background-image: url('/assets/avatars/6.png')"></div>
  <input type="radio" name="avatar" value="x/../private">
</div>
```

Như bạn thấy, chúng ta đã vượt qua được quy tắc và người dùng đã cập nhật ảnh đại diện. Thủ thuật này hoạt động vì khi máy chủ web nhận được yêu cầu cho x/../private, nó biết rằng chuỗi ../ có nghĩa là di chuyển lên một thư mục, và yêu cầu này giờ đây được dịch thành /private.

Khi xem mã nguồn trang của biểu mẫu ảnh đại diện, bạn sẽ thấy ảnh đại diện hiện tại chứa nội dung từ thư mục /private được mã hóa base64. Hãy giải mã nội dung này và nó sẽ hiển thị một cờ mà bạn có thể nhập bên dưới.

Bây giờ tôi sẽ thử tìm flag:

- Đầu tiên, đăng kí tài khoản:



Tôi đang ở nơi thay đổi ảnh đại diện, tôi sẽ thử kiểm tra source code.

```
<div class="row text-center">
    <div class="col-xs-4">
        <div class="avatar-image" style="background-image: url('/assets/avatars/1.png')"></div>
        <input type="radio" name="avatar" value="assets/avatars/1.png">
```

Sau đó, tôi sẽ thử update avartar và kiểm tra lại source code.

```
                            <div class="row text-center">
    <div class="col-xs-6 col-xs-offset-3">
        <div><strong>Current Avatar</strong></div>
        <div class="avatar-image" style="background-image: url(
    </div>
</div>
```

Nội dung đã được mã hóa thành dạng base64.

Giờ chúng ta sẽ thử đổi lại thành private, nhớ là chọn đúng ảnh đại mà chúng ta cần private

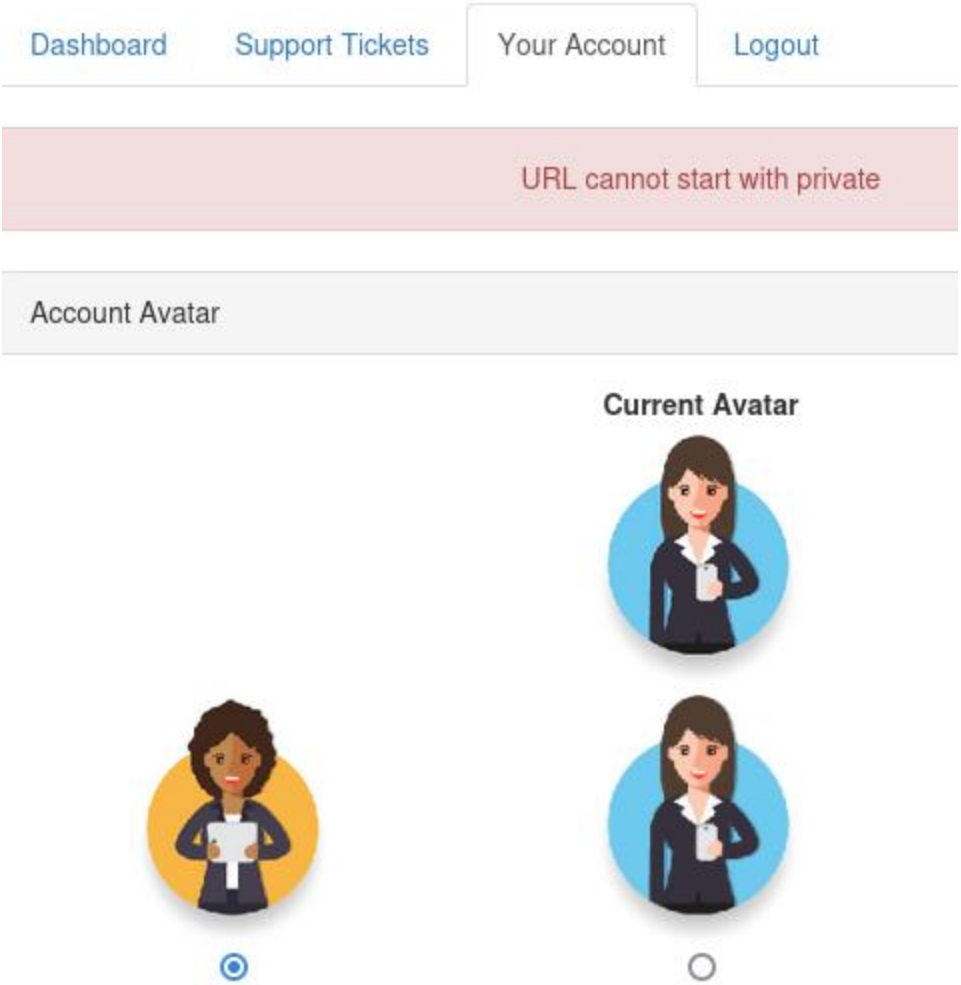
Ở đây tôi chọn:

Chỉnh thành private.

```
<div class="col-xs-4">
    <div class="avatar-image" style="background-image: url('/assets/avatars/1.png')"></div>
    <input type="radio" name="avatar" value="private">
div.row > div.col-md-8.col-md-offset-2 > div.row > div.col-md-6.col-md-offset-3 > form > div.panel.panel-default > div.panel-body > div.row.text-center > div.col-xs
```

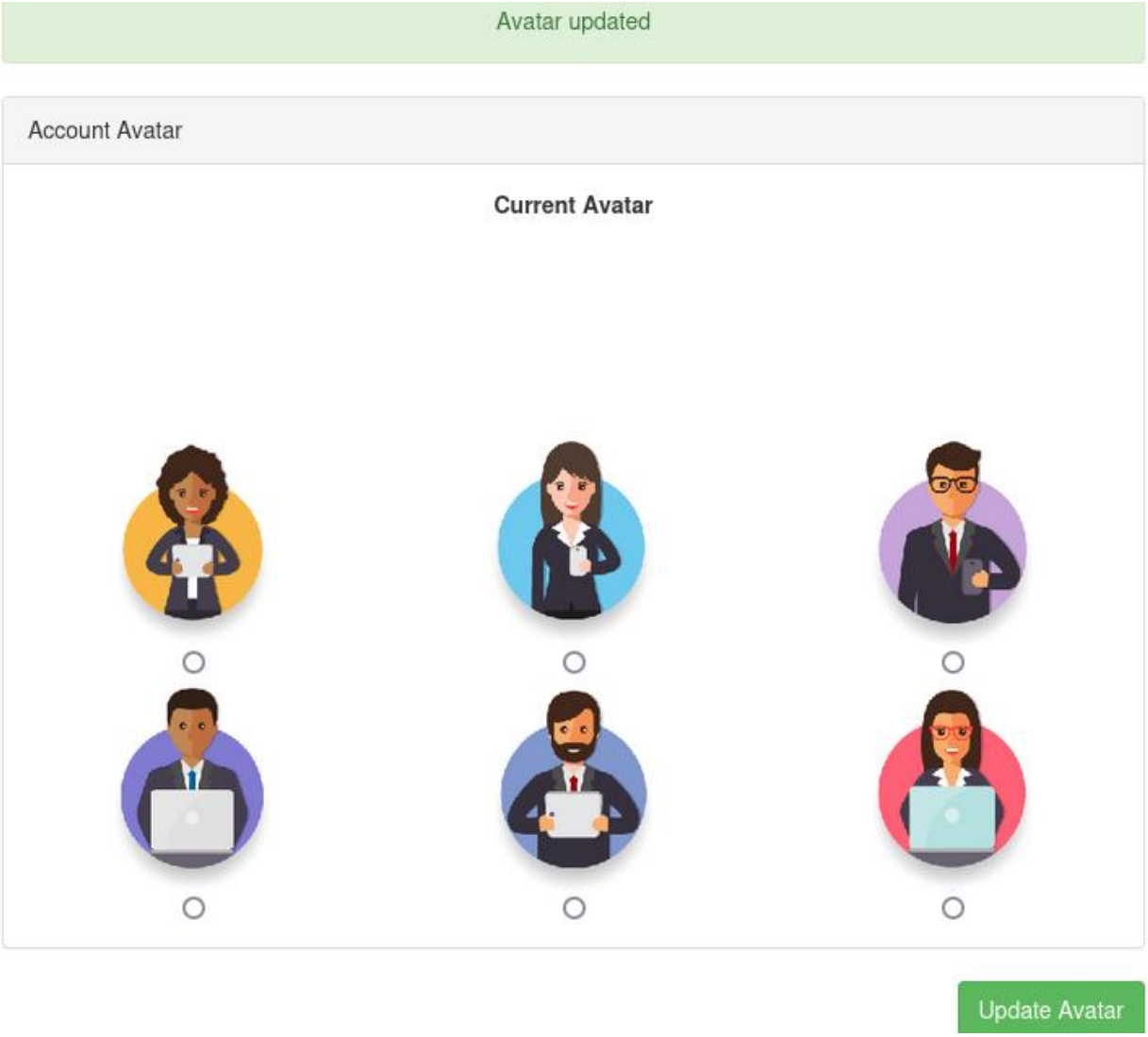
Update Avatar

Kết quả:



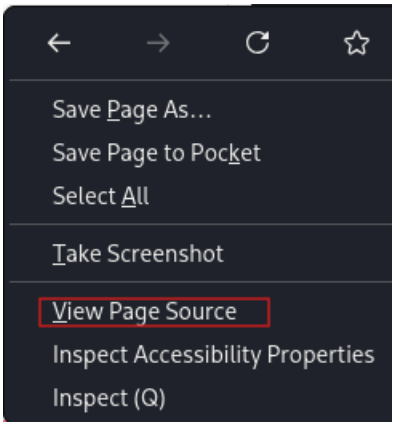
Chúng ta sẽ thử thay đổi giá trị trong ô value, thêm x/../private.

```
<div class="col-xs-4">
  <div class="avatar-image" style="background-image: url('/assets/avatars/1.png')"></div>
  <input type="radio" name="avatar" value="x/../private">
```



Thành công.

Chúng ta sẽ thử kiểm tra mã nguồn trang.



```
<div class="row text-center">
    <div class="col-xs-6 col-xs-offset-3">
        <div><strong>Current Avatar</strong></div>
        <div class="avatar-image" style="background-image: url()"></div>
    </div>
```

Ta sẽ đem đoạn mã này và truy cập [Base64 Decode and Encode - Online](#) để giải mã.

Kết quả.

Decode from Base64 format

Simply enter your data then push the decode button.

VEhNe1lPVV9XT1JLRURfT1VUX1RIRV9TU1JGfQ==)

For encoded binaries (like images, documents, etc.) use the file upload form a little further down

UTF-8 Source character set.

Decode each line separately (useful for when you have multiple entries).

Live mode OFF Decodes in real-time as you type or paste (supports only the UTF-8 charac

DECODE Decodes your data into the area below.

THM{YOU_WORKED_OUT_THE_SSRF}

What is the flag from the /private directory?

THM{YOU_WORKED_OUT_THE_SSRF} ✓ Correct Answer